CHAPITRE 05

Fondamentaux de la sécurité

15 % de l'examen

Livre : V2 ch. 2 et 7 ; V1 ch. 14



Le vocabulaire de la sécurité

Terme	Définition	Exemple
Vulnérabilité	Faiblesse d'un système	Mot de passe par défaut
Menace	Danger qui peut l'exploiter	Pirate qui scanne Internet
Exploit	Moyen concret d'exploitation	Script de test des mots de passe
Atténuation	Mesure qui réduit le risque	Politique de mots de passe



Confidentialité

Seuls les autorisés lisent



Intégrité

Rien n'est modifié



Disponibilité

Le service fonctionne

Les principales attaques

Attaque	Principe	Pilier visé
DoS / DDoS	Saturer une cible ; DDoS = des milliers de machines	Disponibilité
Usurpation	Falsifier une adresse IP ou MAC	Intégrité
Homme du milieu	S'intercaler, par empoisonnement ARP	Confidentialité
Reconnaissance	Scanner pour repérer les failles	Préparation
Hameçonnage	Faux courriel ou faux site	Confidentialité
Logiciels malveillants	Virus, ver, cheval de Troie, rançongiciel	Tous
Mots de passe	Force brute, dictionnaire	Confidentialité
Couche 2	Saturation MAC, faux DHCP, saut de VLAN	Tous

Un programme de sécurité

Sensibilisation

Tous les utilisateurs : repérer l'hameçonnage, verrouiller sa session

Formation

Les équipes techniques, en profondeur

Accès physique

Salles fermées, badges, armoires verrouillées

À retenir : la plupart des incidents commencent par une erreur humaine.

Sécuriser l'accès aux équipements

```
enable secret Cisco@2026
service password-encryption
security passwords min-length 10
login block-for 120 attempts 3 within 60
username admin privilege 15 secret Admin@2026
line vty 0 4
 login local
 transport input ssh
 exec-timeout 5 0
```

Commande	Effet
enable secret	Mot de passe haché
min-length 10	10 caractères min.
login block-for	Bloque après 3 échecs
exec-timeout 5 0	Déconnexion à 5 min

Au-delà : MFA (mot de passe + téléphone ou jeton) et certificats.

AAA : authentifier, autoriser, tracer



Critère	RADIUS	TACACS+
Origine	Norme ouverte	Cisco
Transport	UDP 1812 / 1813	TCP 49
Chiffrement	Mot de passe seul	Paquet entier
Usage	Accès des utilisateurs	Administration des équipements

802.1X : contrôler l'accès port par port



Les listes de contrôle d'accès (ACL)



Haut en bas

Lecture ligne par ligne

1re correspondance

Elle seule s'applique

Refus implicite

deny any invisible à la fin

Type	Numéros	Filtre sur	Placement
Standard	1–99, 1300–1999	Source uniquement	Près de la destination
Étendue	100–199, 2000–2699	Source, destination, protocole, ports	Près de la source

Raccourcis : host 192.168.10.5 = une seule adresse ; any = toutes les adresses.

ACL : deux exemples résolus

```
! Standard : seul le réseau
! Informatique administre en SSH
ip access-list standard ADMIN-SSH
 permit 192.168.30.0 0.0.0.255
line vty 0 4
 access-class ADMIN-SSH in
```

Vérifier : show access-lists affiche le nombre de correspondances (matches) de chaque ligne.

```
! Étendue : la RH ne joint pas le
! serveur comptable, mais navigue
ip access-list extended RH-FILTRE
 deny ip 192.168.20.0 0.0.0.255
  host 192.168.10.100
 permit tcp 192.168.20.0 0.0.0.255
  any eq 80
 permit tcp 192.168.20.0 0.0.0.255
  any eq 443
 permit udp 192.168.20.0 0.0.0.255
  any eq 53
interface g0/0.20
 ip access-group RH-FILTRE in
```

Sécurité de couche 2 : port security

```
interface f0/5
 switchport mode access
 switchport port-security
 switchport port-security maximum 2
 switchport port-security mac-address sticky
 switchport port-security violation restrict
```

maximum 2 : téléphone IP + PC.

sticky : apprend et inscrit les MAC.

Violation	Bloque	Journalise	Désactive le port
protect	Oui	Non	Non
restrict	Oui	Oui	Non
shutdown (défaut)	Oui	Oui	Oui (err-disabled)

DHCP snooping et inspection ARP

DHCP snooping

Bloque les faux serveurs DHCP : réponses autorisées seulement sur les ports de confiance

```
ip dhcp snooping
ip dhcp snooping vlan 10,20
interface g0/1
 ip dhcp snooping trust
```

Inspection ARP (DAI)

Vérifie l'ARP avec la table du snooping ; bloque l'empoisonnement ARP

```
ip arp inspection vlan 10,20
interface g0/1
 ip arp inspection trust
```

Les VPN

VPN site à site

- Tunnel permanent entre deux routeurs ou pare-feu
- Exemple : relier une agence au siège par Internet
- Protocole : IPsec

VPN d'accès distant

- Tunnel ouvert par un logiciel sur le poste
- Exemple : collaborateur en télétravail
- Protocole : souvent TLS

La sécurité des réseaux sans fil

Protocole	Chiffrement	Statut
WEP	RC4	Cassé, à proscrire
WPA	TKIP	Obsolète
WPA2	AES (CCMP)	Standard actuel
WPA3	AES (GCMP), SAE	Recommandé

Mode Personnel

Clé partagée (PSK) ; WPA3 la remplace par SAE

Mode Entreprise

802.1X + RADIUS, un compte par utilisateur

À retenir du chapitre 5



- Triade CIA : confidentialité, intégrité, disponibilité.
- enable secret, SSH, comptes locaux ou AAA : le minimum sur chaque équipement.
- ACL : haut en bas, première correspondance, refus implicite.
- Standard près de la destination ; étendue près de la source.
- Port security : protect, restrict, shutdown.
- RADIUS = UDP, utilisateurs ; TACACS+ = TCP 49, administrateurs, tout chiffré.
- Wi-Fi : WPA2 minimum, WPA3 recommandé, mode Entreprise.

À travailler dans le livre : chapitre 5

Vol.	Ch.	Titre du chapitre
V2	2	Security with ACLs
V2	7	Security Fundamentals
V1	14	Cloud and Virtual Private Networks

Pour chaque chapitre

- Le lire avant ou après la séance
- Faire les written labs
- Faire les review questions
- S'entraîner sur la Test Bank en ligne

Exercices du chapitre 5



Corrigés en annexe A

1. Triade CIA : un DDoS, un vol de fichiers clients, un virement modifié ?
2. Quelle commande protège le mode privilégié par un mot de passe haché ?
3. Une ACL contient seulement deny host 10.1.1.5 : et le reste du trafic ?
4. ACL étendue : interdire 192.168.40.0/24 vers 10.0.0.10 en Telnet, autoriser le reste.
5. Où placer une ACL standard, et pourquoi ?
6. Violation shutdown, 3e adresse MAC pour un maximum de 2 : que se passe-t-il ?
7. Quel mécanisme bloque un faux serveur DHCP ?
8. Deux différences entre RADIUS et TACACS+ ?
9. Quel mode de WPA3 choisir dans une banque, et pourquoi ?